

APIM Policy Pilot

Why GitHub Copilot for API Security

Live Demo Guide - 10 Minutes

Duration:	10 minutes
Format:	Live VS Code + Browser Demo
Presenter:	Keep this PDF open on laptop
Apps:	localhost:3002 (Pitch) + VS Code

Pre-Demo Setup Checklist

Complete ALL items before the audience arrives. Verify each one.

Applications & Terminals

- [] VS Code open with how_APIM_works repo
- [] GitHub Copilot extension installed and signed in
- [] Terminal 1: Backend API running (cd sample-api && npm start) on port 4000
- [] Terminal 2: APIM Policy Pilot running (cd pitch-deck && npm run dev) on port 3002

Browser Tabs

- [] Tab 1: <http://localhost:3002> (APIM Policy Pilot app)
- [] Tab 2: GitHub repo https://github.com/sautalwar/how_APIM_works

Environment Cleanup

- [] CLOSE: Slack, Teams, email notifications
- [] CLOSE: Personal browser tabs, bookmarks bar hidden
- [] VS Code font size: 16px+ (Ctrl+= to increase)
- [] Terminal font size: 14px+
- [] Delete any leftover policies/demo-new-policy.xml from prior runs

Quick Smoke Test

- [] Open <http://localhost:3002> -- app loads with hero section
- [] VS Code Copilot Chat opens (Ctrl+Shift+I)
- [] Test Copilot: type 'hello' in chat -- get response

Segment 1: "The Problem"

Duration: 2 min **Type:** BROWSER

Step 1: Open APIM Policy Pilot (30s)

[DO] Switch to browser. Navigate to `http://localhost:3002`

[EXPECT] The APIM Policy Pilot hero page loads with the headline: 'You have APIM. You have Kong.'

Step 2: Set the Stage (45s)

[SAY] You have APIM or Kong protecting your APIs. Great. But who writes the policies? Who reviews them? Who ensures they cover OWASP?

Pause for effect. Let the questions land.

Step 3: Show the Gap (45s)

[DO] Scroll down to 'The Gap Nobody Talks About' section

[SAY] Your gateway handles runtime enforcement -- rate limiting, JWT validation, CORS. But the policy LIFECYCLE -- authoring, reviewing, validating, deploying -- that's where things fall through the cracks.

Point at the two columns: 'What Your Gateway Does' (green checks) vs 'What Nobody Does Today' (red X marks).

[SAY] Let me show you how GitHub Copilot fills this gap.

VALUE: Establishes the problem before showing the solution. The audience recognizes their own gap.

Segment 2: "AI Policy Authoring -- Live"

Duration: 3 min **Type:** VS CODE (LIVE)

Step 1: Switch to VS Code (15s)

- [DO]** Alt+Tab to VS Code
- [DO]** Open or create a new file: policies/demo-new-policy.xml
- [NOTE]** This is the LIVE coding moment. Take a breath. Go slow.

Step 2: Open GitHub Copilot Chat (15s)

- [DO]** Open GitHub Copilot Chat: Ctrl+Shift+I or click the Copilot icon in sidebar
- [EXPECT]** Copilot Chat panel opens on the right side of VS Code

Step 3: Give Copilot a Natural Language Policy Requirement (30s)

- [TYPE]** In Copilot Chat, type: "I need an APIM policy for our payment processing API. Requirements: JWT authentication with Azure AD, rate limiting at 100 requests per minute per subscription, request body validation max 50KB, mask all error details from callers, add security headers X-Content-Type-Options and X-Frame-Options"
- [DO]** Press Enter and wait for Copilot to generate

Step 4: Watch Copilot Generate the Policy (60s)

- [EXPECT]** Copilot generates a complete APIM XML policy with: validate-jwt, rate-limit-by-key, validate-content, on-error masking, and set-header elements
- [SAY]** Look at what just happened. I described what I need in English. Copilot generated gateway-native XML -- not boilerplate, but a policy customized to MY requirements. It knows APIM policy schema, it knows the elements, it knows the attributes.

VALUE: This is not generic code completion. Copilot understands APIM policy semantics. It generates validate-jwt with the right structure, rate-limit-by-key with correct attributes, on-error with safe masking patterns.

Step 5: Copy into the Policy File (15s)

[DO] Copy the generated policy into policies/demo-new-policy.xml

[NOTE] If Copilot output is incomplete, ask: 'Can you complete the rest of the policy including outbound and on-error sections?'

Segment 3: "AI Explains Its Decisions"

Duration: 2 min **Type:** VS CODE (LIVE)

Step 1: Ask Copilot to Explain the Policy (15s)

[TYPE] In Copilot Chat: "Explain what each element in this policy does and which OWASP API threat it mitigates"

[DO] Press Enter and wait for response

Step 2: Review the OWASP Mapping (45s)

[EXPECT] Copilot maps each policy element to specific OWASP API Top 10 threats:

- API2 Broken Authentication -> validate-jwt
- API4 Unrestricted Resource Consumption -> rate-limit-by-key
- API8 Security Misconfiguration -> set-header (security headers)
- API3 Broken Property-Level Auth -> validate-content

[SAY] This is the part that changes everything. Copilot doesn't just write the policy -- it explains WHY each element is there and maps it to industry standards. Your team can REVIEW with confidence because they understand the reasoning.

VALUE: Junior developers can write senior-level policies. The AI provides the domain expertise that would normally require years of security specialization.

Step 3: Ask About Coverage Gaps (Optional) (30s)

[TYPE] Optionally ask Copilot: "What OWASP threats are NOT covered by this policy? What should I add?"

[EXPECT] Copilot identifies gaps like missing CORS config (API8), no IP filtering (API6), no audit logging (API9)

[SAY] Copilot doesn't just generate -- it also tells you what's MISSING. That's the review layer that no gateway vendor provides.

Segment 4: "Interactive Demo in the App"

Duration: 2 min **Type:** BROWSER

Step 1: Switch to the Pitch App (15s)

[DO] Switch to browser, APIM Policy Pilot at <http://localhost:3002>

[DO] Scroll down to the "See Copilot Author a Policy" section

Step 2: Run the Payment API Scenario (30s)

[CLICK] "Secure Payment API" button

[SAY] Watch the flow -- requirement goes in, policy comes out, and then Copilot explains every decision.

[EXPECT] Typing animation shows policy being generated character by character, then review items appear one by one with explanations

Step 3: Run the Partner API Scenario (30s)

[CLICK] "Partner Integration API" button

[SAY] Different requirement, completely different policy. Per-partner rate limits, IP allowlisting, mutual TLS, audit logging. All from a natural language description.

[EXPECT] Different policy XML appears with ip-filter, validate-client-certificate, log-to-eventhub elements

Step 4: The Bottom Line (30s)

[DO] Scroll to "The Bottom Line" section at the very bottom

[SAY] Your gateway is the lock. GitHub Copilot is the locksmith who builds it right. Your team reviews and approves -- with AI explaining every decision.

VALUE: The interactive demo reinforces the live VS Code demo. Audience sees the same concept in a polished visual format.

Segment 5: "The Workflow"

Duration: 1 min **Type:** BROWSER

Step 1: Show the Flow Diagram (30s)

[DO] Scroll back up to "From Intent to Protected API" flow diagram

[SAY] The complete workflow: Describe what you need, Copilot generates it, your team reviews the PR with AI explanations, iterate until it's right, merge and it auto-deploys to your gateway. Every change versioned, every decision documented, every policy validated.

The 5-step flow: 1) Describe -> 2) Generate -> 3) Review -> 4) Iterate -> 5) Deploy

Step 2: Closing Statement (30s)

[SAY] This is Policy-as-Code with AI -- and it's something your gateway vendor doesn't offer. Your gateway enforces. GitHub ensures the enforcement is correct.

VALUE: Ends on a clear differentiator: gateways enforce, GitHub ensures correctness. Complementary, not competitive.

Competitive Comparison: Gateway Native vs GitHub Copilot + Actions

Use this table if asked 'why not just use our gateway tools?' -- emphasize COMPLEMENTARY, not replacement.

Capability	APIM/Kong Native	GitHub Copilot + Actions
Policy Authoring	Manual XML/YAML editing	AI generates from English
OWASP Mapping	Documentation only	AI maps threats to elements
Policy Review	Manual review (expertise req.)	AI explains each element
Change Tracking	Limited or none	Full Git history, PR diffs
Consistency	Varies per developer	AI ensures patterns across APIs
Deployment	Manual portal/CLI	PR merge triggers deploy
Audit Trail	Gateway logs only	Git commits + PR conversations

KEY MESSAGE: Your gateway is the RUNTIME. GitHub is the LIFECYCLE. They work together.

OWASP API Top 10 -> APIM Policy Quick Reference

Use this if the audience asks about specific OWASP threats. Copilot knows all of these mappings.

ID	Threat	APIM Policy Element	What It Does
API1	Broken Object-Level Auth	validate-jwt + scope claims	Enforce per-object access
API2	Broken Authentication	validate-jwt + openid-config	Verify identity tokens
API3	Broken Property-Level Auth	validate-content + set-body	Schema validation
API4	Resource Consumption	rate-limit-by-key + quota	Throttle per client
API5	Broken Function-Level Auth	choose + validate-jwt/op	Per-operation auth
API6	Unrestricted Sensitive Flows	ip-filter + client-cert	Network-layer isolation
API7	Server-Side Request Forgery	set-backend-service list	Backend allowlisting
API8	Security Misconfiguration	set-header + cors	Harden response headers
API9	Improper Inventory Mgmt	api-version-set + headers	Version deprecation
API10	Unsafe API Consumption	validate-content (outbound)	Validate backend resp.

Hard Questions & Prepared Answers

Anticipate these questions. Deliver answers with confidence.

Q: We already have APIM/Kong. Why do we need this?

A: Your gateway ENFORCES policies. But who WRITES them correctly? Who ensures they cover OWASP? Who reviews changes? That's the gap. Your gateway is the lock -- this ensures the lock is built right. We are complementary to your gateway, not a replacement.

Q: Can Copilot really understand APIM policy XML?

A: Yes -- Copilot has been trained on millions of APIM policies. It knows validate-jwt, rate-limit-by-key, set-header, choose/when, on-error -- all the elements and their correct attributes. I just showed you a live example. Want to try another scenario right now?

Q: What about Kong? Does this only work with APIM?

A: Copilot understands both APIM XML policies and Kong declarative YAML config. The workflow -- describe, generate, review, deploy -- works the same regardless of gateway vendor. The principles are gateway-agnostic.

Q: How is this different from code scanning / GHAS?

A: Code scanning finds vulnerabilities in application code. This is about INFRASTRUCTURE POLICY authoring -- generating and reviewing the security configurations that protect your APIs at the gateway level. Different layer, complementary value.

Q: What if Copilot generates an incorrect policy?

A: That's exactly why we use Pull Requests. Copilot generates a starting point -- a very good starting point. Your team reviews with AI explanations. The PR process catches issues before anything reaches your gateway. It's a collaboration, not blind automation.

Q: Can we customize the OWASP rules?

A: Absolutely. The security scanner in this repo uses a YAML rules file. You can add rules specific to your organization's standards, disable rules that don't apply, and set severity thresholds. It's fully extensible.

Q: What's the pricing?

A: GitHub Copilot Business is \$19/user/month. GitHub Actions is free for public repos and includes 2,000 minutes/month for private repos. There's no additional infrastructure cost -- it runs entirely in GitHub. No extra servers, no extra licenses.

Fallback Plans

If something goes wrong during the live demo, use these recovery paths.

Scenario 1: Copilot Chat is Slow or Unresponsive

[SAY] "The AI is processing a complex policy. While we wait, let me show you the interactive demo in the app."

[DO] Switch to browser, open <http://localhost:3002>, scroll to the demo section

[CLICK] "Secure Payment API" button to show the pre-built scenario

[NOTE] Return to VS Code once Copilot responds. Say: 'And here is the live result.'

Scenario 2: Copilot Generates Unexpected Output

[SAY] "Interesting -- let me refine the prompt. This actually shows why the PR review step matters."

[DO] Adjust the prompt to be more specific. Add constraints like 'Use APIM XML policy format with validate-jwt element'

[NOTE] Frame it as a positive: iteration is PART of the workflow. This is why you don't blindly deploy.

Scenario 3: Pitch App (localhost:3002) Won't Load

[DO] Open the policies/ directory in VS Code file explorer

[DO] Open policies/global-policy.xml and policies/api-level-policy.xml side by side

[SAY] "Let me walk you through real policies from this repo instead."

[NOTE] Walk through the XML showing validate-jwt, rate-limit-by-key, set-header, on-error sections manually.

Scenario 4: VS Code or Copilot Extension Crashes

[DO] Pivot entirely to the browser-based demo at localhost:3002

[SAY] "Let me show you the end-to-end flow in our visual demo while I restart my editor."

[DO] Walk through all three scenarios in the app: Payment API, Public Catalog, Partner API

[NOTE] The pitch app contains enough content to carry a full 10-minute demo on its own.

Timing Summary -- 10 Minute Demo

Segment	Title	Time	Location	Key Action
1	The Problem	2 min	Browser	Show the gap
2	AI Policy Authoring	3 min	VS Code	Live Copilot gen
3	AI Explains Decisions	2 min	VS Code	OWASP mapping
4	Interactive App Demo	2 min	Browser	Click scenarios
5	The Workflow	1 min	Browser	5-step flow

Key URLs Quick Reference

- APIM Policy Pilot: <http://localhost:3002>
- Backend API: <http://localhost:4000>
- GitHub Repo: https://github.com/sautalwar/how_APIM_works

Key Copilot Chat Prompts (Copy-Paste Ready)

PROMPT 1 -- Policy Generation:

```
I need an APIM policy for our payment processing API.  
Requirements: JWT authentication with Azure AD,  
rate limiting at 100 requests per minute per subscription,  
request body validation max 50KB,  
mask all error details from callers,  
add security headers X-Content-Type-Options and X-Frame-Options
```

PROMPT 2 -- OWASP Explanation:

```
Explain what each element in this policy does  
and which OWASP API threat it mitigates
```

PROMPT 3 -- Gap Analysis (Optional):

```
What OWASP threats are NOT covered by this policy?  
What should I add?
```

Closing Notes for the Presenter

KEY THEMES TO REINFORCE THROUGHOUT:

- Complementary, not competitive -- Copilot enhances your existing gateway investment
- The gap is in the LIFECYCLE, not the RUNTIME -- gateways enforce, GitHub ensures correctness
- AI + Human review -- Copilot generates, your team approves via Pull Requests
- Policy-as-Code -- every change versioned, every decision documented, every deploy automated
- Vendor-agnostic principles -- works with APIM, Kong, or any gateway that uses config files

THINGS TO AVOID:

- Do NOT mention GHAS, code scanning, SARIF, or secret scanning -- this demo is about policy authoring
- Do NOT position against the gateway -- always say 'complementary'
- Do NOT rush the live Copilot demo -- let the audience watch it generate in real time
- Do NOT apologize if Copilot is slow -- pivot to fallback and frame it positively

RECOMMENDED NEXT STEPS TO OFFER:

- 'Let's schedule a deeper technical session where we build policies for YOUR APIs'
- 'I can share this repo so your team can try Copilot with your own policy files'
- 'We have a GitHub Copilot Business trial -- want me to set one up for your team?'